



Disclaimer: This document is provided for informational and educational purposes only as part of GRC Mastery training course. While we have made reasonable efforts to ensure the accuracy of the information contained herein, it is not intended to be professional advice. We make no warranties or representations of any kind, express or implied, regarding the accuracy or completeness of the information provided. You should not rely on this document for any commercial decision-making. By using this document, you agree to hold us harmless from any and all damages or losses arising from your use of this document.

GRCMastery.com



Business Continuity & Disaster Recovery Policy

Date	Version	Author	Description	Approved By	Last Updated	Review Frequency	Next Review



Purpose

This policy defines the framework for maintaining business operations and recovering critical services during and after disruptive incidents, including natural disasters, cyberattacks, hardware failures, and cloud service outages.

Scope

Covers all business-critical systems, processes, personnel, and third-party services within Stark Industries Inc.'s ISMS scope, including its SaaS platform, infrastructure (AWS), code repositories, and internal operations.

Definitions

Term	Definition
Business Continuity (BC)	The ability to maintain essential functions during a disruption
Disaster Recovery (DR)	The technical restoration of IT systems and infrastructure
RTO (Recovery Time Objective)	The maximum acceptable time to restore a system
RPO (Recovery Point Objective)	The maximum acceptable data loss measured in time

Policy Objectives

- Minimise disruption to operations
- Protect life, data, and assets during disasters
- Ensure recovery of critical services within acceptable timeframes
- Meet customer, legal, and contractual obligations

Critical Functions and Systems (A.5.32)

The following are classified as critical and must have defined BC/DR plans:



Function	System	RTO	RPO
SaaS Platform Availability	AWS EC2, RDS	4 hours	15 minutes
Source Code Repositories	GitHub	24 hours	1 hour
Internal Communication	Slack, Email	8 hours	1 hour
Customer Support Services	CRM / ticketing tool	8 hours	1 hour

Disaster Scenarios Addressed

- Cloud infrastructure outage (AWS region failure)
- Ransomware or malware attack
- Insider sabotage or accidental data deletion
- Power or internet disruption at HQ
- Loss of critical third-party services

Business Continuity Planning

- All departments must identify:
 - Critical processes
 - Minimum staffing levels
 - Workarounds for technology failures
- Remote work readiness is maintained for all employees
- Communication trees are updated quarterly for all teams

Disaster Recovery Planning (A.5.33)

- Backups are:
 - Automated, encrypted, and versioned
 - Tested monthly
 - Retained for a minimum of 90 days
- Infrastructure-as-code enables rapid redeployment of cloud environments
- DR procedures are stored offline and accessible to key personnel



Testing and Maintenance

- BC/DR plan is:
 - Reviewed **annually**
 - **Tested semi-annually** through simulations or failover drills
 - Updated after any significant incident or organisational change

Communication During Disruption

- Internal updates via Slack + SMS fallback
- Customer communication plan includes:
 - Email templates
 - FAQ updates
 - Incident status page (if available)

Roles and Responsibilities

Role	Responsibilities
CEO	Approves BC/DR strategy and authorises emergency declarations
Information Security Manager	Maintains the BC/DR plan and coordinates response
IT Infrastructure Engineer	Executes technical recovery procedures
Department Heads	Define and test department-level continuity plans
All Staff	Know their role in the event of a disruption

Policy Review

- This policy is reviewed **annually** or upon significant change to the environment or regulatory requirements.